Ders 7 Çalışma Özeti

Ders 7 Çalışma Özeti

Genel Konular

- Cookie tabanlı saldırılar
  - Cookie theft, JavaScript üzerinden `document.cookie` erişimi ve cookie'nin saldırgan sunucusuna aktarılması açıklanır.
  - HTTPOnly ve Secure cookie bayrakları cookie güvenliğini artıran mekanizmalar olarak ele alınır.
- Cross-Site Request Forgery
  - Kullanıcının oturumu açıkken saldırganın başka bir site üzerinden hedef uygulamaya istek göndermesi CSRF olarak tanımlanır.
  - Tarayıcı uygun cookie'leri otomatik eklediği için hedef uygulama isteği meşru kullanıcıdan gelmiş sanabilir.
- CSRF savunmaları
  - Secret token validation ile her form veya işlem için tahmin edilemeyen, session'a bağlı token kullanılır.
  - Token statik olmamalı, oturum ve işlem bağlamıyla ilişkilendirilmelidir.
- SameSite cookie
  - Cookie'nin cross-site isteklerde gönderilip gönderilmeyeceğini belirleyen ek savunma katmanıdır.
  - Strict gibi modlar CSRF riskini azaltır.
- SQL injection giriş
  - Kullanıcı girdisinin SQL sorgusuna kontrolsüz eklenmesi, saldırganın sorgu mantığını değiştirmesine izin verir.

Hocanın Özellikle Vurguladığı Kısımlar

- Cookie tek başına güvenilir kimlik doğrulama kanıtı değildir
  - Cookie çalınabilir veya tarayıcı tarafından saldırganın tetiklediği isteğe otomatik eklenebilir.
- CSRF durum değiştiren işlemlerde tehlikelidir
  - Para transferi, parola değiştirme veya ayar güncelleme gibi işlemler özellikle korunmalıdır.
- Token session'a özgü olmalıdır
  - Tahmin edilebilir veya sabit token savunma sağlamaz.
- HTTPOnly JavaScript erişimini engeller
  - Cookie ağ üzerinden gönderilebilir; ancak `document.cookie` ile okunamaz.

Kısa Tekrar Notları

- Cookie theft: cookie değerinin çalınması.
- HTTPOnly: JavaScript cookie okuyamaz.
- Secure: cookie yalnız HTTPS üzerinden gönderilir.
- CSRF: kullanıcının tarayıcısına yetkili istek yaptırma.
- SameSite: cross-site cookie gönderimini sınırlar.
- SQL injection: girdiyle SQL komut mantığını değiştirme.

Detaylı Açıklamalar

- Cookie hırsızlığında saldırgan, hedef origin altında çalışan bir script aracılığıyla cookie değerini okuyup kendi sunucusuna gönderebilir. HTTPOnly bayrağı bu tür erişimi engeller; Secure bayrağı ise cookie'nin yalnız şifreli bağlantıda gönderilmesini sağlar.
- CSRF saldırısında saldırgan cookie'yi okumak zorunda değildir. Kullanıcı hedef uygulamada oturum açmışsa, tarayıcı hedef domaine yapılan isteğe cookie'yi otomatik ekler. Hedef uygulama yalnız cookie'ye bakarak karar verirse saldırganın tetiklediği işlem başarıya ulaşabilir.
- Secret token validation, sunucunun ürettiği ve kullanıcının formuna yerleştirdiği gizli token'ın istekle birlikte geri gelmesini bekler. Saldırgan token'ı bilemediği için geçerli istek oluşturamaz. SameSite cookie de tarayıcı düzeyinde ek koruma sağlar.
- SQL injection, web uygulamasının kullanıcı girdisini SQL sorgusuna doğrudan eklemesiyle oluşur. Girdi veri olarak değil komut parçası olarak yorumlandığında saldırgan sorgu koşulunu değiştirebilir, tabloları sorgulayabilir veya hassas veri elde edebilir.
- **Not:** İsterseniz bu dersin altyazı (.srt) dosyasını Gemini Notebook gibi bir yapay zeka aracına yükleyerek ders hakkında daha detaylı soru-cevaplar yapabilir ve dersi verimli çalışabilirsiniz.